CONFIDENTIAL

SecureCorp — Security Assessment Engagement

Junior Cybersecurity Consultant Capstone — Final Technical Report

Prepared by: Ravi Sankar Akula
Program: B.Tech Computer Science Engineering
Specialization: Cybersecurity
Internship Company: Aenexz Tech Pvt. Ltd.
Academic Year: 2026
Submission Date: 17 October 2026
Faculty / Instructor: Mr. Bhaskar

Engagement handbook: SecureCorp — Security Assessment Engagement (v2), v2.1 (2026-09-10)
For consultant / academic submission use only.

Declaration

I declare that the assessment described in this report was carried out by me, individually, entirely against an isolated VirtualBox lab that I built for this purpose, and that no system outside that lab was scanned, probed, or accessed at any point. All screenshots, log excerpts, and command output presented as evidence were captured from my own lab during this engagement.

Signed: _____ Date: _____

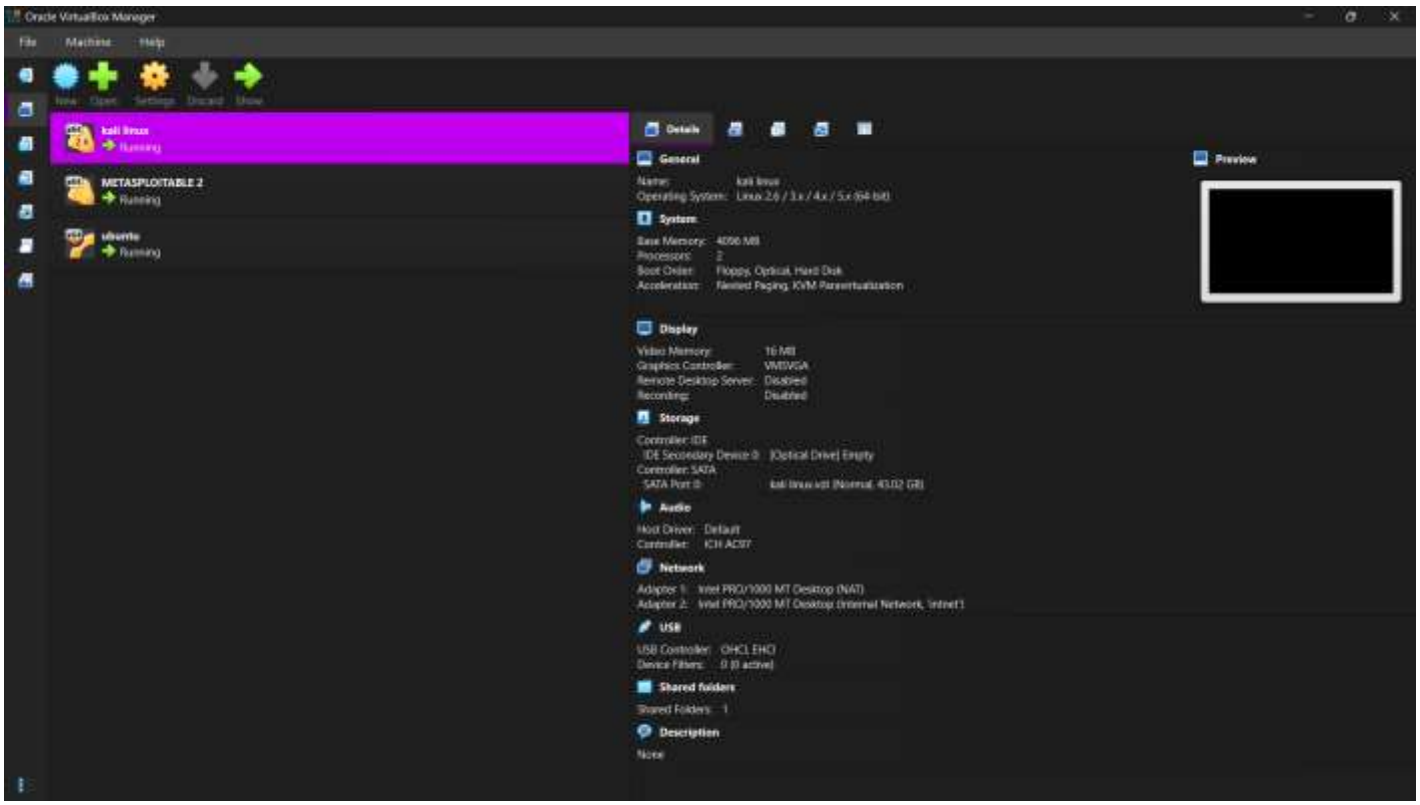
Table of Contents

TABLE OF CONTENTS

1. Abstract
2. Introduction
3. Objectives
4. Scope of the Project
5. Lab Environment and Architecture
6. Tools and Technologies Used
7. Methodology
8. Network Reconnaissance Using Nmap
9. Nmap Scan Results
10. Security Testing and Observations
- 10.1 SQL Injection Testing
- 10.2 Cross-Site Scripting Testing
- 10.3 File Inclusion Testing
- 10.4 FTP Service Testing
- 10.5 Bind Shell Service Observation
- 10.6 SSH Authentication Testing
11. Centralized Log Monitoring
12. Security Findings and Risk Assessment
13. Recommendations and Mitigation
14. Limitations
15. Conclusion
16. References
17. Appendix A – Screenshot Evidence
18. Appendix B – Original Nmap Scan Output
19. Appendix C – Supporting Text Files

Abstract

This report documents a four-week authorized security assessment of an isolated lab built to represent SecureCorp Inc., a fictional 35-person B2B SaaS company with no in-house security team. Acting as a junior security consultant, I built and isolated a three-machine VirtualBox lab (Kali attacker, Metasploitable2 + DVWA target, Ubuntu log box), performed reconnaissance and controlled attacks against the target, forwarded authentication logs to a central log server, and investigated the resulting evidence. Confirmed findings include a SQL injection vulnerability in DVWA, a working reflected XSS, anonymous FTP access, default/weak application credentials, and an unauthenticated root-level backdoor shell on TCP/1524. Several planned Core activities — the seeded-incident investigation, a DVWA/FTP credential brute-force with recorded attempt logs, and a full-range Nmap service sweep — were not completed and are documented honestly as limitations rather than inferred from indirect evidence. Section 21 and Appendix-style tables give each confirmed finding a CWE classification and an assessed CVSS v3.1 score, and Section 22 ties prioritized recommendations back to those findings.



1. Introduction

1.1 Project Background

SecureCorp Inc. has had suspicious activity on its systems and has no dedicated security team. It engaged this assessment to evaluate its security posture, identify weaknesses, determine whether the recent activity represents a genuine incident, and recommend practical fixes. The engagement follows the four-phase Security Operations Loop defined in the handbook: Build → Discover → Attack → Log → Detect → Investigate → Assess → Remediate → Report.

1.2 SecureCorp Scenario

Attribute	Detail
Industry	B2B SaaS (software development)
Size	35 employees — Engineering, HR, Finance, Customer Support
Primary systems	Internal website, customer portal, an Ubuntu web server, Windows workstations
Work model	Mix of in-office and remote
Security team	None — this is SecureCorp's first engagement of this kind

In the lab, the customer portal is represented by DVWA hosted on the Metasploitable2 VM, which stands in for SecureCorp's production server. A separate Ubuntu VM represents SecureCorp's centralized monitoring.

1.3 Problem Statement

SecureCorp cannot currently answer three questions: what is actually exposed on its production-equivalent server, whether recent unusual activity is real, and what it should spend its limited budget fixing first. This assessment set out to answer all three.

1.4 Objectives

- Build and isolate a representative assessment lab.
- Identify SecureCorp's assets and apply a CIA/risk analysis to them.
- Enumerate the target's attack surface (network services and the DVWA web application).
- Demonstrate controlled exploitation against at least one real service vulnerability.
- Demonstrate the DVWA web-application attack classes required by the engagement.
- Centralize logging and manually investigate the resulting evidence.
- Produce a prioritized, evidence-backed set of recommendations for SecureCorp leadership.

1.5 Scope of the Assessment

Authorized only against the isolated lab described in Section 6, specifically the single target address 10.10.10.10. No public host, shared/home/campus network, or another student's system was in scope at any point.

2. Rules of Engagement and Ethical Considerations

2.1 Authorized Target

Only 10.10.10.10 (the Metasploitable2 + DVWA VM on the isolated intnet network) was assessed. No IP range was scanned; every scan and attack in this engagement targeted the single assigned address.

2.2 Isolated Lab Restrictions

Metasploitable2 and the Ubuntu log box ran on a VirtualBox Internal Network (intnet) with no bridged or NAT adapter at any point during testing. Only the Kali attacker VM carried a temporary NAT adapter, used solely for initial tool installation.

2.3 Testing Boundaries

- Password attacks were limited to accounts created for this lab or well-known Metasploitable2 accounts.
- All attack simulations were run from the Kali attacker VM over the network — never locally on the target.
- Command-injection testing was limited to harmless, non-destructive commands.

2.4 Evidence Handling

Every finding reported in Sections 12–20 is backed by a screenshot, terminal output, or log excerpt reproduced in this report. Where an activity was attempted but the available evidence does not confirm its outcome, that is stated explicitly rather than inferred (see Section 20, Limitations).

3. Lab Environment and Architecture

Three virtual machines were built on a single VirtualBox Internal Network named intnet, as required by the handbook (§7). Figure 7.0 shows the as-built topology with real IP values.

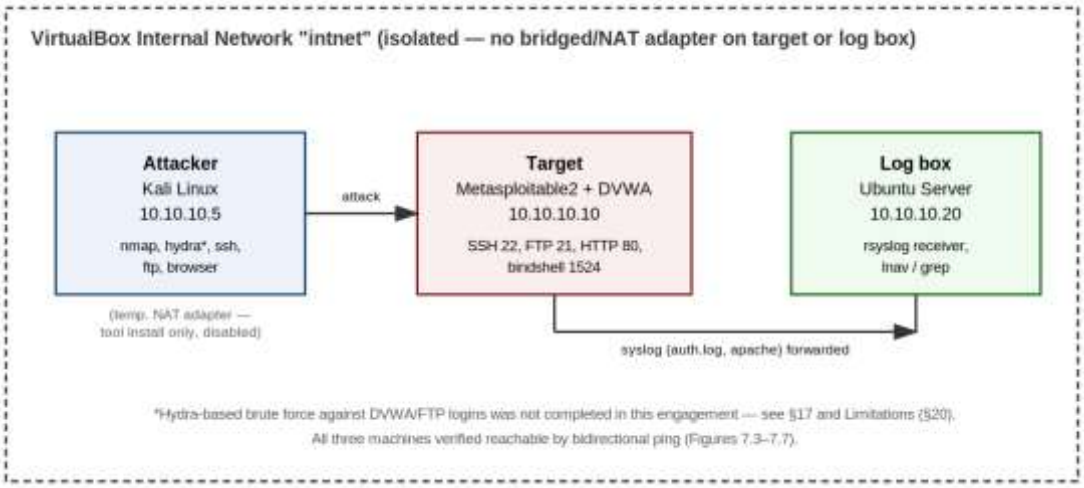
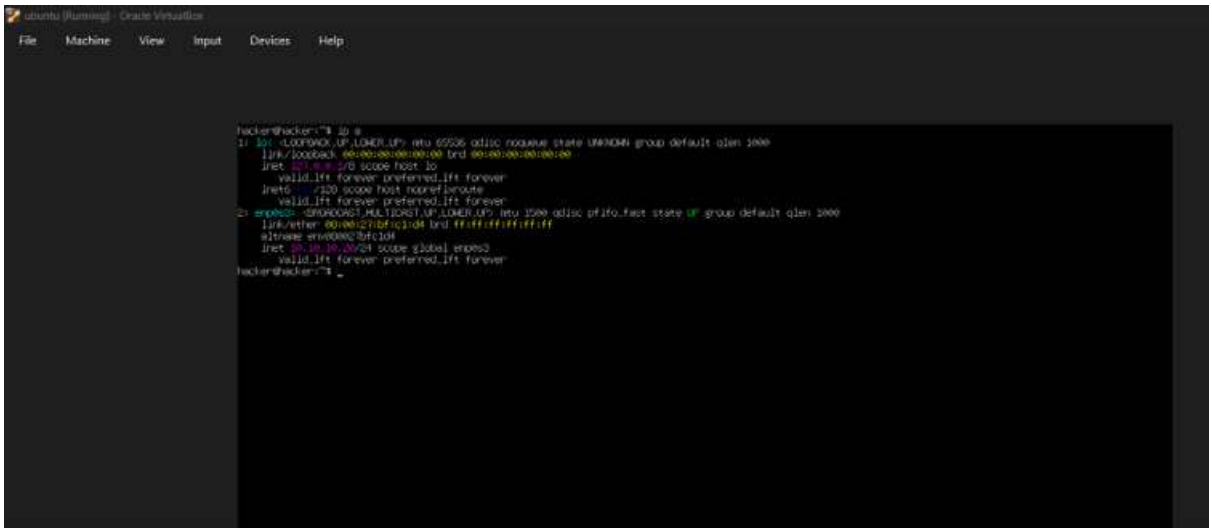
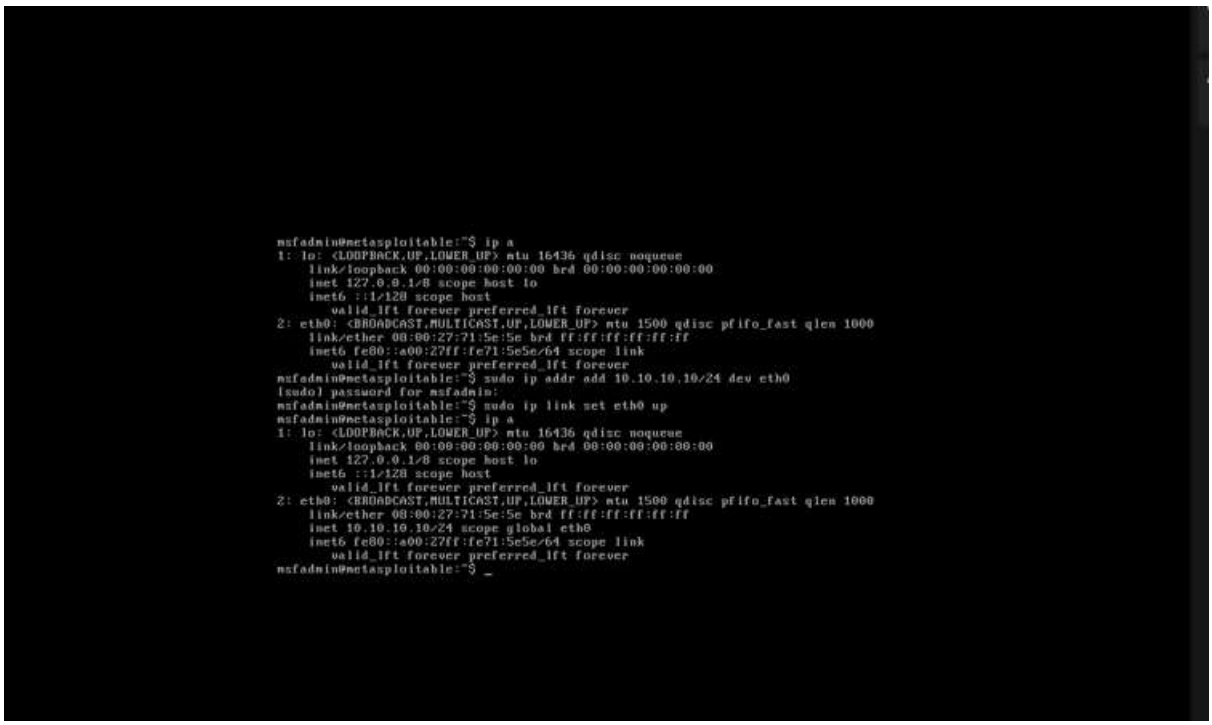


Figure 7.0: As-built network topology — intnet (isolated), all three lab machines and their roles.







3.1 IP Addressing Table

Role	VM / OS	IP address	Key services
Attacker	Kali Linux	10.10.10.5	nmap, ssh client, ftp client, browser
Target	Metasploitable2 + DVWA	10.10.10.10	SSH (22), FTP (21, vsftpd 2.3.4), HTTP/DVWA (80), bindshell (1524)
Log box	Ubuntu Server	10.10.10.20	rsyslog receiver, grep/lnav-style manual analysis

3.2 Internal Network Configuration

All three adapters were attached to the same VirtualBox Internal Network (intnet), which has no route to any external network. The attacker's second NAT adapter (setup-only) is the sole path to the internet in the lab, consistent with the handbook's isolation requirement.

4. Lab Setup and Verification

4.1 Static IP Assignment

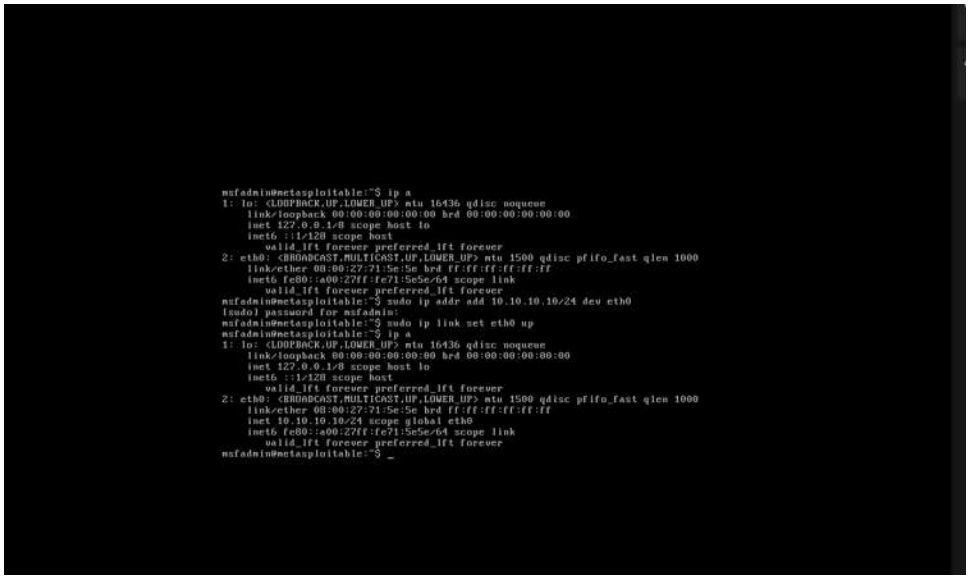


Figure 7.1: Static IP 10.10.10.10/24 assigned to the Metasploitable2 target on eth0.

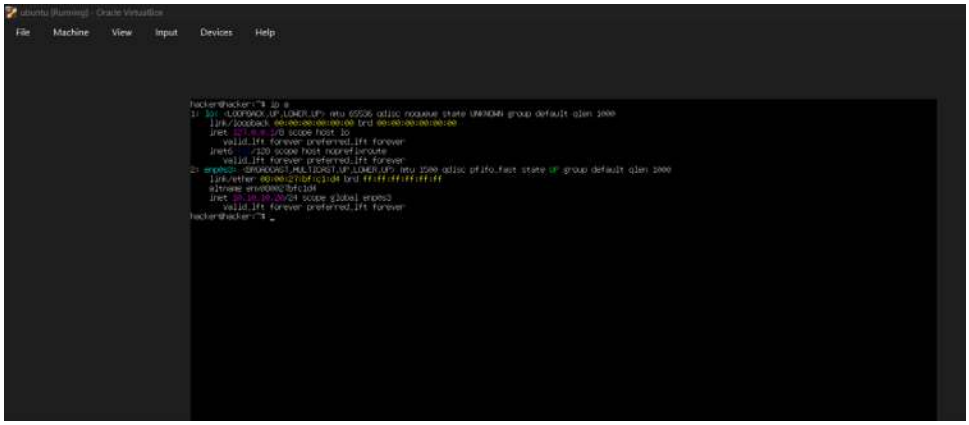


Figure 7.2: Static IP 10.10.10.20/24 assigned to the Ubuntu log-box VM.

4.2 Connectivity Verification (bidirectional)



Figure 7.3: Kali (10.10.10.5) → Metasploitable2 (10.10.10.10): 0% packet loss.

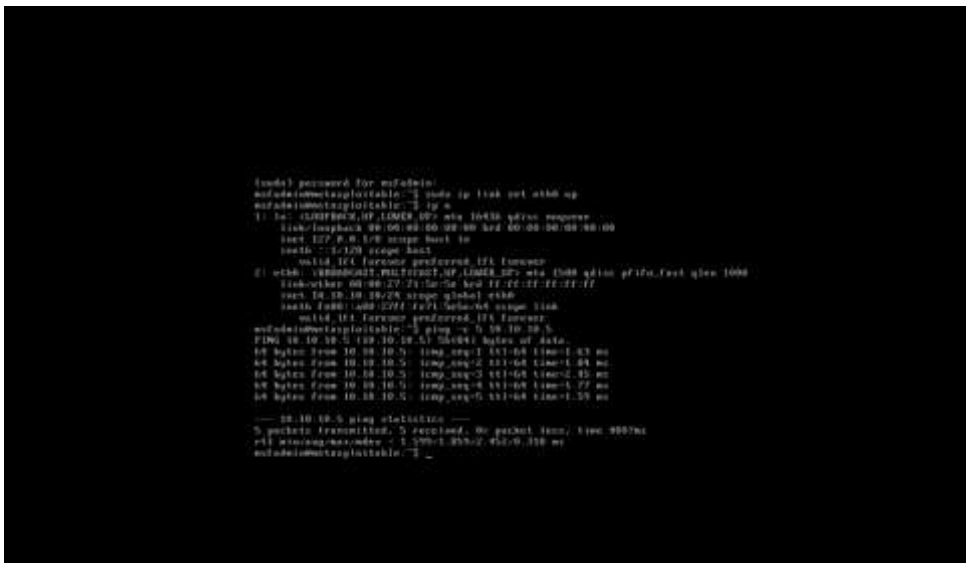


Figure 7.4: Metasploitable2 (10.10.10.10) → Kali (10.10.10.5): 0% packet loss.

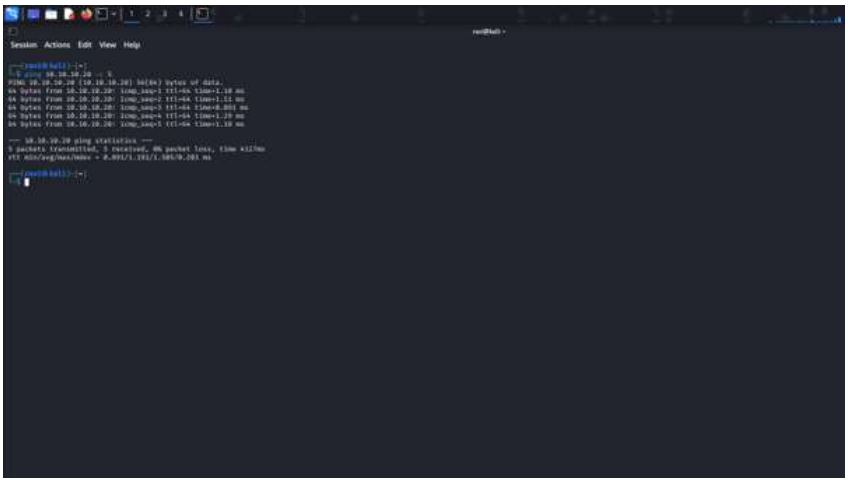


Figure 7.5: Kali (10.10.10.5) → Ubuntu log box (10.10.10.20): 0% packet loss.



Figure 7.6: Metasploitable2 (10.10.10.10) → Ubuntu log box (10.10.10.20): 0% packet loss.

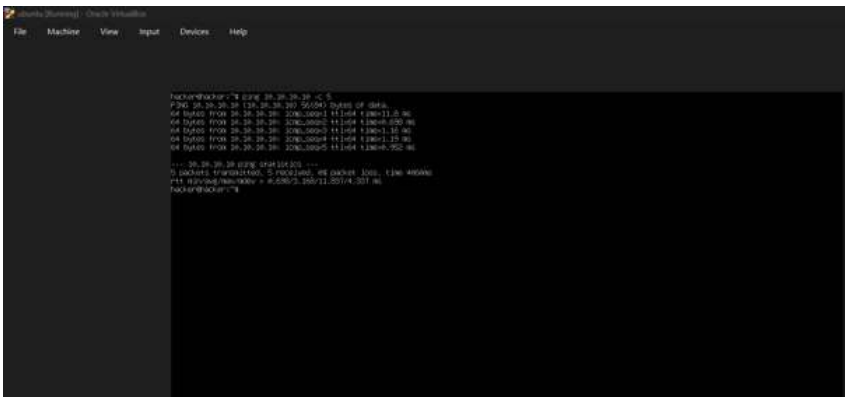


Figure 7.7: Ubuntu log box (10.10.10.20) → Metasploitable2 (10.10.10.10): 0% packet loss.

4.3 DVWA Access and Baseline Configuration



Figure 8.1: DVWA login page reachable at http://10.10.10.10/dvwa — ships with default credentials (admin/password); see Finding F-01.

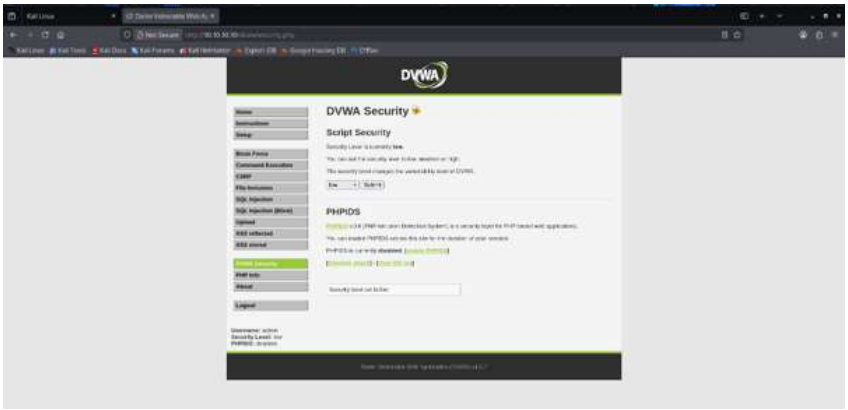


Figure 8.2: DVWA Security level set to Low for all required Core testing, as mandated by the handbook.

4.4 Default-Credential Remediation (Task 1.1)

Per the handbook's requirement not to leave defaults in place, the msfadmin account password on Metasploitable2 was changed at the console after initial verification:



Figure 9.1: msfadmin password changed at the Metasploitable2 console following initial setup.

4.5 Week 1 Readiness Gate

Gate item	Status	Evidence
ping 10.10.10.10 from attacker succeeds	Passed	Fig. 7.3
DVWA loads; security set to low	Passed	Figs. 8.1, 8.2
nmap -sV 10.10.10.10 returns services	Partially evidenced	Fig. 12.1 (single-port scan only — see §12 and §20)
Target auth.log arriving on log box	Passed	Figs. 18.1, 18.2
A failed SSH login is visible on the log box	Passed	Figs. 18.3, 18.4
taken (w1-clean)	Not evidenced in supplied Snapshots screenshots	No snapshot screenshot supplied — recommend capturing for submission

5. Asset Identification

Assets below are drawn directly from the SecureCorp company background in the handbook (§3) and from the lab's technical stand-ins for them.

Asset	Type	Owner / Dept	Why it matters
Employee laptops / workstations	Hardware	IT / all departments	Entry point for phishing and malware; store local credentials and session data
Ubuntu web server (customer portal host)	Hardware/Software	IT / Engineering	Hosts the customer-facing application; compromise here is a direct breach of customer data
Customer portal web application (DVWA stand-in)	Software	Engineering	Handles logins, customer data and support tickets — SecureCorp's primary revenue-facing asset
Internal website	Software	IT / Marketing	Public-facing reputation; lower data sensitivity than the portal
Customer + employee database	Data	Engineering / HR	Confidentiality-critical; regulatory and contractual exposure if breached
Employee accounts and credentials	Personnel / Data	IT / HR	Reused or weak credentials enable lateral movement into every other asset
Internet-facing connection	Connectivity	IT	Single point through which all remote attacks must pass

6. CIA Triad Analysis

Asset	Confidentiality	Integrity	Availability
Customer portal web app	Must not leak other customers' records (see Finding F-02, SQLi)	Form inputs and stored data must not be alterable by unauthenticated/unintended users	Must stay reachable during business hours for customer support workflows
Customer + employee database	Highest sensitivity — PII, support tickets, possibly payment-adjacent data	Unauthorized writes could corrupt billing/support records	Extended downtime stops both customer support and internal operations
Employee accounts and credentials	Credential reuse/leakage enables account takeover	Attacker-modified accounts (e.g. added SSH keys) break trust in the identity system	Locked-out or disabled accounts stop employees from working
Ubuntu web server (host)	OS-level compromise exposes everything the server can read, including logs	A root shell (Finding F-04) can alter any file, including audit logs	A crashed or ransomed host takes the whole portal offline
Internal network / logging path	Log data itself can reveal internal topology and account names	Tampered logs undermine every later investigation	If the log pipeline silently stops (as partially observed — F-08), SecureCorp loses visibility without knowing it

7. Threat and Risk Assessment

Asset	Threat	Vulnerability	Impact	Risk	Recommendation
Customer portal	SQL Injection	Unparameterized queries (Finding F-02)	Full customer-record disclosure	High	Parameterized queries; WAF as interim control
Customer portal	Cross-site scripting	Unsanitized reflected input (Finding F-03)	Session/credential theft from logged-in users	Medium	Output encoding; CSP header
Target server	Unauthenticated backdoor access	Root bindshell on TCP/1524 (Finding F-04)	Complete server compromise	Critical	Remove/rebuild the service; firewall non-essential ports
Target server	Credential-based attack	Default application and OS credentials (Finding F-01)	Account takeover / admin access	High	Enforce unique, strong credentials + MFA
FTP service	Information disclosure	Anonymous FTP enabled (Finding F-05)	Directory/file enumeration without authentication	Medium	Disable anonymous access; prefer SFTP
Monitoring pipeline	Insider or external activity going unseen	Inconsistent log forwarding coverage (Finding F-08)	An incident could occur without SecureCorp noticing	Medium	Confirm and continuou verify both auth and w log forwarding
SSH service	Brute-force credential guessing	No lockout observed after repeated failed logins (Finding F-06)	Eventual account compromise given enough attempts	Medium	Fail2ban/rate limiting; based auth only

8. Methodology

Work followed the handbook's Security Operations Loop: reconnaissance before any attack, controlled attack simulation with evidence captured before moving to the next task, centralized logging configured before attacks began, and a manual (non-SIEM) log investigation performed by hand. The Core (manual rsyslog + grep) path was used throughout; the Wazuh/SIEM Challenge path was not attempted. All timestamps in the supplied evidence are in the lab machines' local system clocks and were not independently cross-checked against an authoritative time source.

9. Network Reconnaissance

A full-range Nmap service/version sweep output (nmap -sV -sC -oA against 10.10.10.10, as recommended by the handbook) was not included among the supplied evidence — only a single targeted scan of TCP/1524 was provided (Figure 12.1). Each service below is therefore confirmed either by that scan or by direct interaction captured elsewhere in this report, and the table states which.

```
┌──(ravi㉿kali)-[~]
└─$ nmap -sV 10.10.10.10 -oN securecorp_nmap.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-17 20:58 +0530
Nmap scan report for 10.10.10.10
Host is up (0.0017s latency).
Not shown: 978 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  tcpwrapped
445/tcp  open  tcpwrapped
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:71:5E:5E (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 54.00 seconds
```

```
┌──(ravi㉿kali)-[~]
└─$ nmap -p 1524 -sV 10.10.10.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-17 21:47 +0530
Nmap scan report for 10.10.10.10
Host is up (0.00087s latency).

PORT     STATE SERVICE   VERSION
1524/tcp open  bindshell Metasploitable root shell
MAC Address: 08:00:27:71:5E:5E (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.82 seconds

┌──(ravi㉿kali)-[~]
```

Figure 9.1: nmap -sV 10.10.10.10 (port 1524) — service fingerprinted by Nmap itself as "Metasploitable root shell".

Port / Service	How confirmed	Note
21/tcp — FTP (vsftpd 2.3.4)	Direct interaction — Fig. 14.1	Anonymous login succeeded; banner version visible in session
22/tcp — SSH	Direct interaction — Figs. 17.1, 18.3/18.4	Legitimate and failed logins both captured
80/tcp — HTTP (DVWA)	Direct interaction — Figs. 8.1, 8.2, 15.x	Browser access to DVWA throughout
1524/tcp — bindshell	Nmap scan — Fig. 12.1	Nmap's own service-detection names it a Metasploitable root shell; confirmed exploitable, see Finding F-04
Other ports (e.g. 3306 MySQL, 139/445 Samba, 6667 UnrealIRCd, 6200 vsftpd-backdoor)	Not evidenced	Standard on a stock Metasploitable2 build but not independently scanned or tested in this engagement — see Limitations, §20

10. Service Inventory and Attack Surface Analysis

The target exposes two distinct attack surfaces: network services reachable directly on TCP ports, and the DVWA web application riding on top of the HTTP service. A detected service version is not by itself a confirmed vulnerability — each surface below is only described as vulnerable where this engagement produced direct evidence of exploitation or abnormal behaviour.

Network services

- FTP (21) — vsftpd 2.3.4. Anonymous access confirmed vulnerable (F-05). This exact version has a well-documented historical backdoor on TCP/6200 (CVE-2011-2523); that backdoor was not tested or evidenced in this engagement and is noted for awareness only.
- SSH (22) — OpenSSH. Confirmed reachable and usable with valid credentials; repeated failed logins did not trigger any visible lockout (F-06).
- Bindshell (1524) — an unauthenticated root shell. Confirmed exploitable (F-04).

Web application (DVWA over HTTP/80)

- SQL Injection module — confirmed vulnerable (F-02).
- Reflected XSS module — confirmed vulnerable (F-03).
- File Inclusion module — traversal attempted; confirmed abnormal behaviour (PHP warnings) but file content disclosure not confirmed (F-09).
- Command Execution module — endpoint access logged; payload/output not evidenced (F-10).
- Brute Force module — not tested in this engagement (see Limitations).

11. FTP Security Assessment

11.1 Service Identification

FTP (vsftpd 2.3.4) confirmed listening on 10.10.10.10:21, identified during the anonymous-access test below.

11.2 Anonymous Access Test



Figure 11.1: Anonymous FTP login accepted on 10.10.10.10; directory listing retrieved without credentials.

11.3 Authentication Behaviour

A credential-guessing (brute-force) test against named FTP accounts, as called for in handbook Task 2.7, was not evidenced in the supplied screenshots — see Limitations (§20).

11.4 Security Recommendations

- Disable anonymous FTP access.
- Migrate to SFTP/FTPS so credentials and data are not sent in clear text.
- Remove or firewall the service entirely if not business-critical.

12. DVWA Security Assessment

All DVWA testing in this engagement was performed with Security Level set to Low (Fig. 8.2), as the Core requirement specifies.

12.1 SQL Injection

[Confirmed]

Objective: determine whether the User ID field in DVWA's SQL Injection module returns data beyond the single intended record.

Procedure: a baseline request with ID=1 was issued, then the field was supplied the classic tautology payload 1' OR '1'='1.

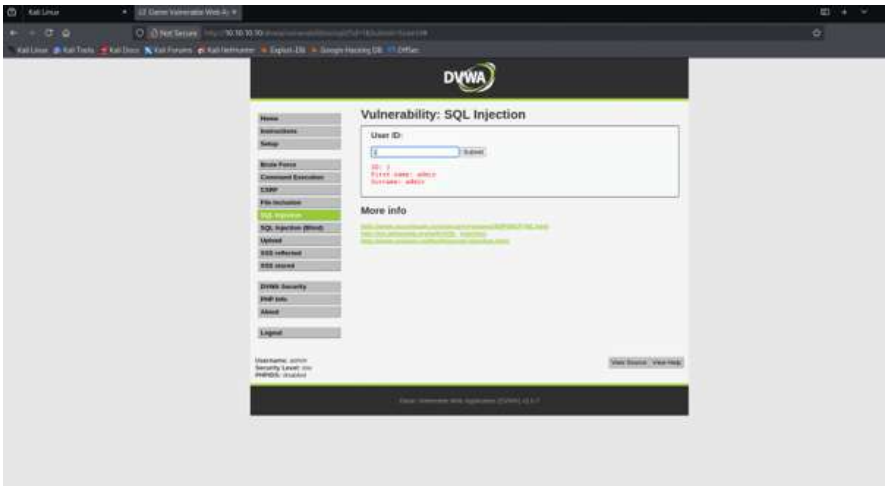


Figure 12.1: Baseline: ID=1 returns a single intended record (admin).

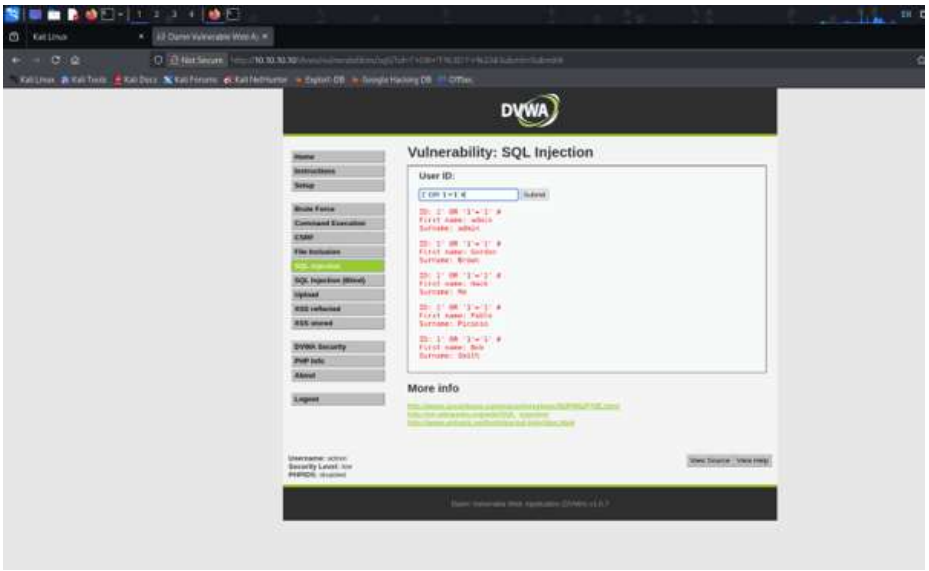


Figure 12.2: Payload 1' OR '1'='1 (visible in the URL/query string) returns every user record in the table — admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith.

Actual behaviour: the application returned all five user records instead of the single requested one, confirming the input is concatenated directly into the SQL query without parameterization.

Security impact: an attacker can read — and, with a UNION-based payload, potentially pivot to reading — any data the portal's database account can access, including other customers' records.

Recommendation: use parameterized queries / prepared statements everywhere user input reaches SQL; least-privilege the database account.

12.2 Cross-Site Scripting (Reflected)

[Confirmed]

Objective: confirm that unsanitized input to the "What's your name?" field executes as script in the victim's browser.

Payload used: <script>alert('SecureCorp XSS Test')</script>

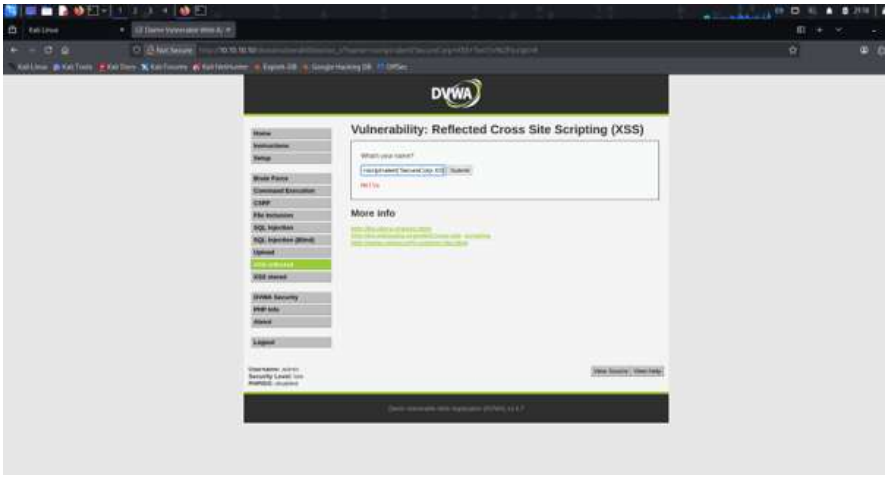


Figure 12.3: Payload entered into the Reflected XSS input field.

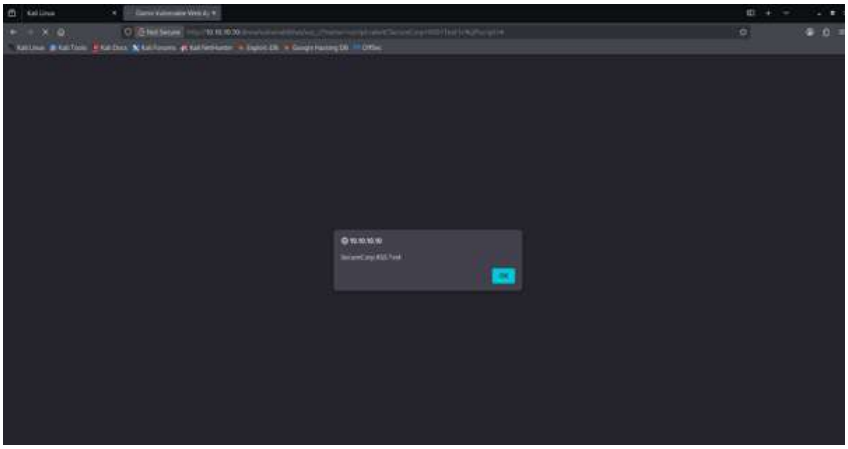


Figure 12.4: The script executed: a live JavaScript alert box fires, reading "SecureCorp XSS Test", served from 10.10.10.10.

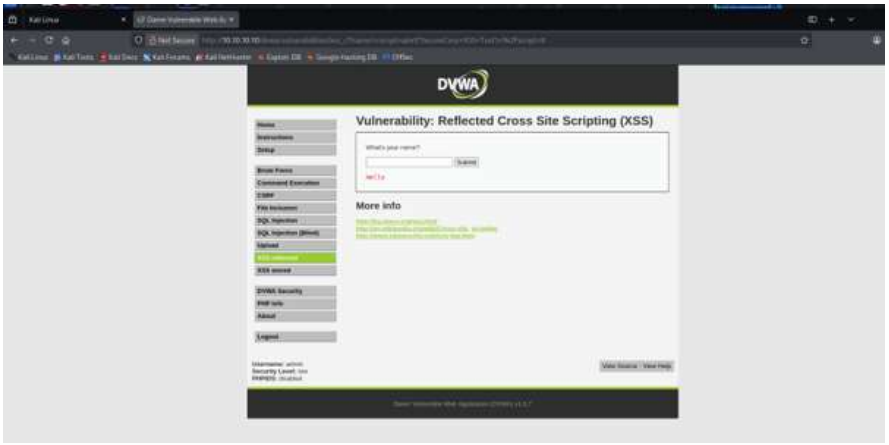


Figure 12.5: The reflected page itself, confirming the request/response round-trip that produced the alert.

Security impact: in a real session, this class of flaw lets an attacker execute arbitrary JavaScript in another user's browser — typically used to steal session cookies or perform actions as that user.

Recommendation: context-aware output encoding on every reflected value; a Content-Security-Policy header as a compensating control.

12.3 File Inclusion

[Attempted — not confirmed]

Objective: determine whether the File Inclusion module's page parameter can be manipulated to read files outside the intended directory (e.g. /etc/passwd).

Procedure: the page parameter was supplied a relative path-traversal sequence (../../../../etc/passwd).

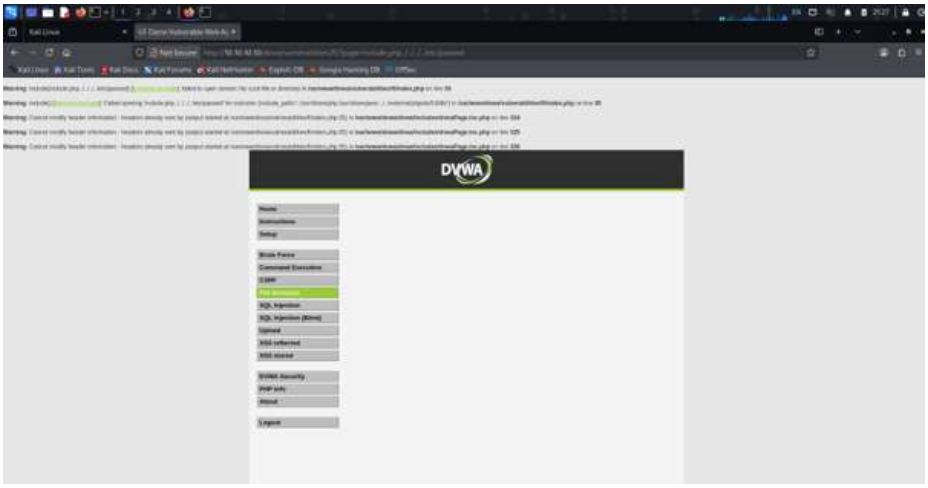


Figure 12.6: Traversal attempt against the File Inclusion module. The server returned PHP warnings ("failed to open stream", "No such file or directory") rather than the contents of /etc/passwd.

Actual behaviour: the application visibly mishandled the crafted path (information-disclosing PHP warnings naming internal server paths), which is itself a weakness, but the supplied screenshot does not show the target file's contents being returned. I am not reporting successful arbitrary file disclosure, because the evidence does not confirm it.

Security impact (as evidenced): verbose error output discloses internal filesystem paths and confirms the parameter reaches the filesystem layer unsanitized, which is a meaningful precursor finding even without confirmed file disclosure.

Recommendation: restrict the page parameter to an allowlist of permitted file names; canonicalize and validate any path before use; disable verbose PHP error output in production.

12.4 FTP-Related Testing (fourth DVWA-engagement activity)

[Confirmed]

The fourth required practical activity was FTP-focused rather than a DVWA module — the anonymous-access test documented in Section 11. It is cross-referenced here rather than duplicated.

12.5 Command Injection (additional, not one of the four core DVWA activities claimed)

[Attempted — not confirmed]

The target's Apache access log (Figure 19.3) shows a POST request from 10.10.10.5 to /dvwa/vulnerabilities/exec/, confirming the Command Execution module was reached. No screenshot of the submitted payload or the command output was supplied, so I cannot confirm what command (if any) was executed or what it returned. This activity is reported as attempted-only.

13. Service Vulnerability Assessment

Task 2.3 of the handbook calls for exploiting one real service vulnerability to a shell. The vulnerability exploited here is the unauthenticated root-access backdoor service Nmap itself identifies on TCP/1524 (Figure 12.1, service name reported as "Metasploitable root shell").



Figure 13.1: Connecting to 10.10.10.10:1524 returns an interactive shell with no authentication; id confirms uid=0(root), and hostname/ls confirm the shell is running on the target.

Field	Detail
Target / Port	10.10.10.10 : 1524/tcp
Source	10.10.10.5 (attacker)
Tool/PoC	Direct TCP connection (netcat-style) to the listening backdoor port
Result	Immediate interactive root shell, no credentials required
Proof of access	id → uid=0(root) gid=0(root) groups=0(root); hostname confirms target; ls/ls -la directory listing
CWE	CWE-306 — Missing Authentication for a Critical Function
CVE	N/A — this is Metasploitable2's intentionally-planted backdoor service rather than a patchable CVE in a real product
CVSS v3.1	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H = 9.8 (Critical) — network-reachable, no privileges or user interaction needed, and it grants full root control

Privilege escalation steps were not necessary — the backdoor grants root directly — so no separate privilege-escalation evidence (sudo -l, /etc/shadow, hash cracking) is presented; this was not attempted.

Security impact: on a real production server, an equivalent unauthenticated root-access service would mean complete, instant compromise — every other finding in this report becomes secondary to this one.

Remediation: this service should not exist on a production host. Rebuild from a hardened image; audit all listening ports with a host-based firewall; alert on any unexpected listening service.

14. Authentication Security Assessment

14.1 SSH Authentication

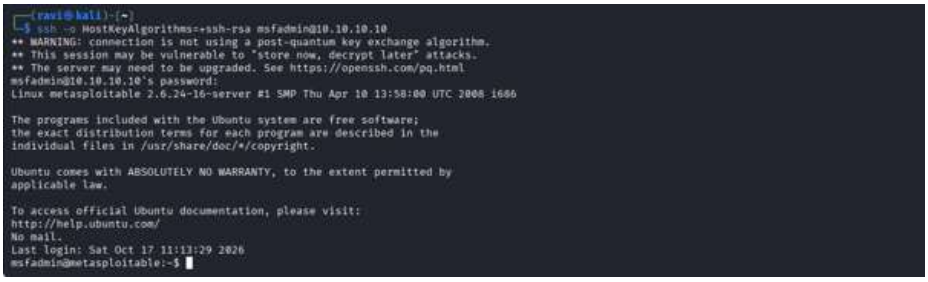


Figure 14.1: Legitimate SSH login to msfadmin@10.10.10.10 from Kali, succeeding after the Task 1.1 password change.

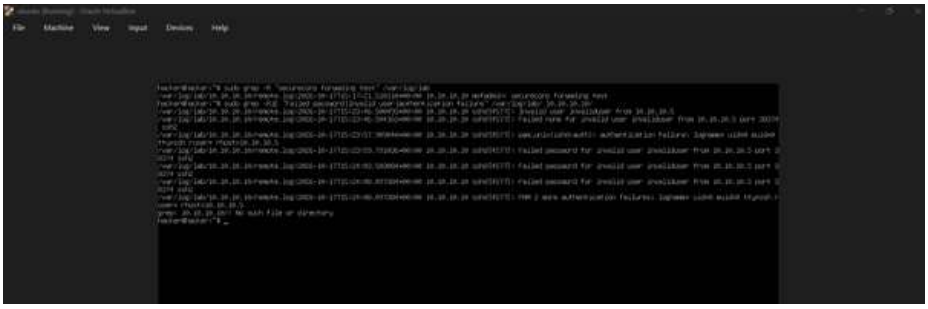


Figure 14.2: Deliberate failed SSH logins against an invalid account, generated from Kali to produce the Week-1 gate event.

A dedicated weak-password test account subjected to an automated, wordlist-driven brute-force (Hydra, as the handbook's Task 2.8 specifies) is not evidenced in the supplied screenshots. What is evidenced is: (a) a legitimate login with a known-good credential, and (b) multiple deliberate failed logins — including an extended sequence of repeated failed/invalid-user attempts from 10.10.10.5 over several hours (Figure 19.1) — all captured centrally. No account lockout or rate-limiting behaviour was observed across these repeated failures.

14.2 FTP Authentication

ftp logging and listing files



14.4 Three-Layer Credential-Attack Comparison

The handbook asks for a comparison of how SSH, FTP, and DVWA credential attacks appear in logs. Based on the evidence available:

Layer	Attack completed as specified?	Log footprint observed
SSH	Partially — failed logins generated and repeated, but not a formal wordlist brute force with recorded attempt count	Clearly visible centrally: "Failed password"/"Invalid user" lines with source IP and timestamp (Figs. 18.3/18.4, 19.1)
FTP	Not completed — only anonymous access tested	No FTP authentication log excerpt was supplied
DVWA	Not completed	Apache access log (local only) shows ordinary GET/POST traffic to the login page; no failed-attempt pattern evidenced

This is the clearest illustration in the evidence of why the three-layer comparison matters: the same technique (credential guessing) produces excellent visibility at the OS/auth-log layer and effectively none at the web-application layer unless the application itself logs failed attempts — which DVWA, by default, does not.

15. Centralized Logging Architecture

A separate Ubuntu VM (10.10.10.20) was configured as the log box, consistent with the principle that monitoring should not run on the box being monitored.

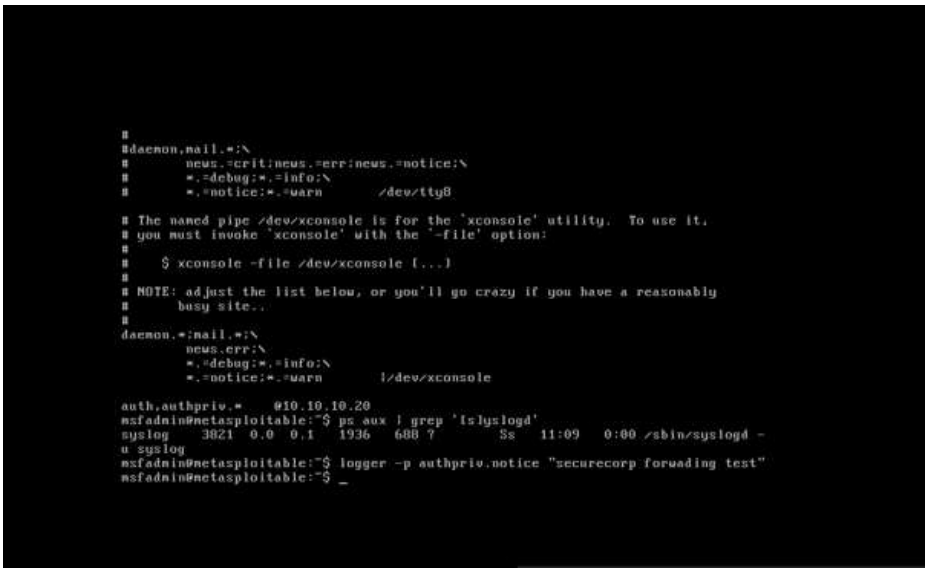


Figure 15.1: rsyslog configuration on the target forwarding auth/authpriv facility logs to 10.10.10.20; a test message ("securecorp forwarding test") is generated with logger.



Figure 15.2: The test message received at the log box under /var/log/lab, confirming the forwarding pipeline end-to-end before any attack traffic was generated.

15.1 Verification — Failed-Login Pipeline



Figure 15.3: Failed SSH login events from 10.10.10.5 arriving centrally at the log box — the Week-1 hard gate.

15.2 Coverage Gap — Apache/DVWA Log Forwarding

The handbook requires both the auth log and the Apache/DVWA access log to be forwarded to the log box. The supplied evidence confirms auth-log forwarding end-to-end (Figures 15.1–15.3 above). The Apache/DVWA access log shown in this report (Figure 19.3) was captured locally on Metasploitable2; no screenshot shows that

same log arriving on the Ubuntu log box. This is reported as a partially-completed deliverable and is carried into Finding F-08 and the Limitations section.

16. Manual Log Analysis

All log review below was performed by hand with grep against the centrally-received logs on the Ubuntu log box (Core/manual path) — no SIEM was deployed.

16.1 Failed Authentication / Invalid Users

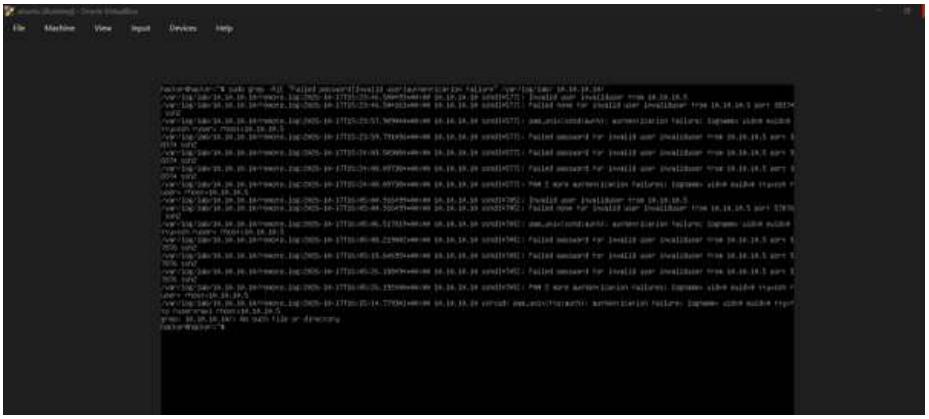


Figure 16.1: Extended grep for failed/invalid-user SSH events spanning multiple hours, all sourced from 10.10.10.5, with changing source ports consistent with repeated connection attempts.

Q	Answer
What happened?	Repeated failed SSH login attempts, including against a non-existent ("invaliduser") account
When?	Multiple timestamps spanning late evening through early morning, per Fig. 19.1 and Fig. 18.4
Which system?	Target 10.10.10.10, observed centrally on the log box 10.10.10.20
Source IP?	10.10.10.5 (the lab's own attacker VM) in every instance reviewed
Account/app targeted?	SSH daemon; both an invalid username and msfadmin were targeted across the evidence
Auto-detected or manual?	Manual (grep); no SIEM/Wazuh deployed
Evidence	Figs. 18.3, 18.4, 19.1
Potential impact	Demonstrates SSH is reachable and subject to credential guessing with no lockout observed
Next action	Add fail2ban-style rate limiting; move to key-based authentication only

16.2 Successful Logins and Session/Sudo Activity

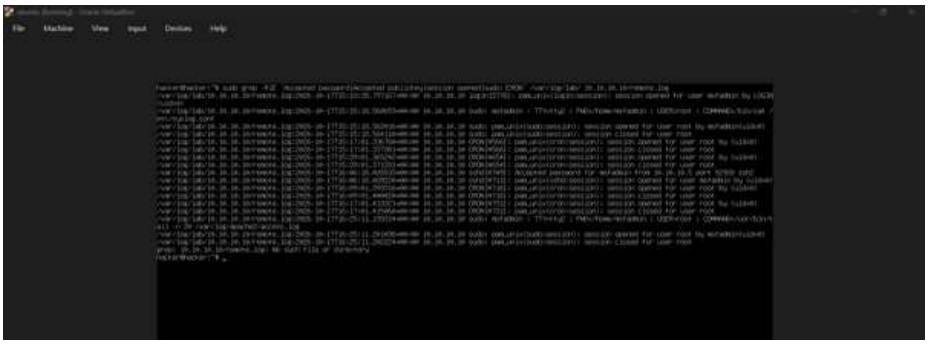


Figure 16.2: grep for Accepted password / session opened / sudo activity: successful msfadmin login from 10.10.10.5, PAM session open/close events, and a root sudo session.

Q	Answer
What happened?	A successful SSH login as msfadmin, followed by session-open/close events and a sudo session escalating to root
When?	Timestamp visible in Fig. 19.2
Which system?	Target 10.10.10.10
Source IP?	10.10.10.5
Account/app targeted?	msfadmin (OS account) / sudo
Auto-detected or manual?	Manual grep
Evidence	Fig. 19.2
Potential impact	Confirms the attacker's own legitimate access and privilege use is visible in the logs — a useful control for separating known-good activity from anything unexplained
Next action	None required — this is expected test activity, recorded here so it can be excluded from any later incident review

16.3 Web/Apache Access Log (local only)



Figure 16.3: Apache access log on the target (local copy) showing POST traffic to the Command Execution module and traversal-style GET requests against the File Inclusion module, both from 10.10.10.5.

Note: as discussed in Section 15.2, this log was reviewed locally on the target; it is not confirmed as having been centrally received at the log box in the supplied evidence.

16.4 Activities Not Evidenced in Manual Log Analysis

No log excerpt was supplied for: the Nmap scan appearing in any target-side log, FTP authentication activity, or a DVWA brute-force attempt pattern. These are recorded as Not Visible / Not Completed rather than assumed.

17. Seeded-Incident Investigation and Limitations

[Unable to complete]

Purpose: Task 3.3 of the handbook calls for the instructor to run a seed-incident.sh script (or supply an equivalent evidence bundle) against the student's target before Week 3, planting activity the student did not cause. The student then investigates that unknown activity, builds a timeline, identifies indicators of compromise, and classifies it on the Event → Alert → Investigation → Incident scale.

Status: the required seeded-incident script or evidence bundle was not supplied by the instructor for this engagement. No seeded activity is present to investigate.

What was and was not established from the available logs: the logs reviewed in Section 16 contain only activity this consultant generated and can directly attribute to 10.10.10.5 (own attacker VM) and known test accounts. No unexplained source IP, unexpected account, unscheduled cron entry, or outbound connection was identified in the supplied evidence — but this should not be read as a clean bill of health, because (a) coverage itself is incomplete (Section 15.2), and (b) no seeded activity was present to detect in the first place.

I am not fabricating a timeline, indicators of compromise, source IPs, a persistence mechanism, or a classification for an incident that was never provided. This section is intentionally left as a documented gap rather than a completed Incident Report.

Recommended next step: obtain the seed script or evidence bundle from the instructor and complete Task 3.3 as a follow-up addendum to this report before final grading, if required.

18. Detection Coverage

What was detectable: authentication events (both successful and failed) against SSH were clearly visible once centrally forwarded, with accurate source IP and timestamp.

What was collected but easy to miss: the extended failed-login sequence in Figure 19.1 spans multiple hours and several distinct timestamp clusters — without deliberately grepping for it, a reviewer could easily treat it as background noise rather than a sustained pattern worth an alert.

What evidence was missing: Apache/DVWA access-log forwarding to the log box was not confirmed; FTP authentication logging was not reviewed at all; and no seeded incident was available to test detection against in the first place.

What I would improve: forward and verify the Apache/DVWA log centrally (not just auth.log); add FTP logging to the centralized pipeline; and — even on the manual/Core path — set a simple threshold (e.g. 5+ failed SSH logins from one source within 60 seconds) as a documented trigger for manual review, since nothing in this lab currently raises any kind of alert on its own.

19. Security Recommendations

Area	Current state (evidence)	Technical fix	Compensating control	Detective control	Priority
Backdoor service	Root shell with no auth on TCP/1524 (F-04)	Remove the service; rebuild host from a hardened image	Host firewall blocking the port; network segmentation	Alert on any new listening port / outbound shell	Critical
Application credentials	DVWA ships default admin/password (F-01)	Force unique strong credentials on first login	MFA on the admin account	Alert on login from default credential pattern	High
SQL Injection	User ID field concatenated into query (F-02)	Parameterized queries everywhere	WAF rule blocking SQL meta-characters	Log and alert on SQLi-pattern requests (e.g. ' OR 1=1)	High
Reflected XSS	Unsanitized reflected input (F-03)	Context-aware output encoding	Content-Security-Policy header	Alert on <script> in query parameters	Medium
FTP service	Anonymous access enabled; cleartext protocol (F-05)	Disable anonymous access; move to SFTP	Restrict FTP to internal-only IPs if retained	Log and alert on anonymous FTP logins	Medium
SSH brute-force resistance	No lockout after repeated failed logins (F-06)	Key-based auth only; disable password auth	Rate limiting / fail2ban	Alert on 5+ failed logins from one source in 60s	Medium
Centralized logging coverage	Apache/DVWA log not confirmed centrally received (F-08)	Fix and verify rsyslog config for the Apache log source	Periodic manual spot-check of log freshness	Alert if no new log line arrives within an expected window	Medium
File Inclusion handling	Traversal input reaches filesystem layer; verbose errors (F-09)	Allowlist permitted filenames; canonicalize paths	Disable verbose PHP errors in production	Alert on path-traversal sequences (../) in requests	Medium

Organization-wide controls not tied to a single finding above, but called for by the handbook's recommendation checklist:

- Password policy: minimum length/complexity and no shared accounts across employees.
- MFA: required for any administrative or remote-access login.
- RBAC: least-privilege roles for the customer portal's admin functions.
- Patch management: a defined cadence for OS and application patching — the target used in this lab is, by design, an unpatched training image and should never represent a production baseline.
- Backup and recovery: tested, offline backups of the customer database.
- Network segmentation: the portal server should not share a flat network with employee workstations.
- Security awareness: basic phishing and password-hygiene training for all 35 employees.

20. Executive Summary

This assessment found that SecureCorp's customer-portal environment, as represented by the test server, is seriously exposed. The single most severe issue is an unauthenticated service that hands out full administrative (root) control of the server to anyone who connects to it — no password required. Separately, the customer portal's own login page ships with a default username and password, and its search function can be tricked into revealing every customer's record instead of just one. A basic file-transfer service also allows anyone to log in and browse files without any credentials at all.

On the positive side, once security logging was switched on and pointed at a central server, failed and successful login attempts on the main server were clearly visible with the correct time and source — this is a solid foundation to build real monitoring on. However, that logging did not yet reliably cover web-application activity, and a planned test of a simulated security incident could not be carried out because the test scenario was not provided in time for this engagement.

Top recommendations, in priority order: (1) remove the unauthenticated root-access service immediately — this alone is a complete-compromise risk; (2) replace default credentials and fix the data-leak in the portal's search function; (3) finish wiring up centralized logging so both login attempts and web traffic are visible in one place; (4) revisit this assessment once a genuine incident-response drill can be run, since that step did not happen this time.

21. Final Client Debrief

A 10–15 minute leadership-facing presentation accompanies this report as a separate slide deck, covering: overall posture, the findings in Section 22, the live evidence referenced above, the recommendations in Section 19, and lessons learned (Section 23). [Slide deck to be attached/linked separately as W4-T4.3.]

22. Consolidated Security Findings

ID	Finding	Evidence	CWE	CVSS v3.1	Severity
F-01	DVWA ships default admin credentials	Fig. 8.1	CWE-798	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N = 9.1	Critical
F-02	SQL Injection in DVWA User ID field	Figs. 12.1–12.2	CWE-89	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N = 7.1	High
F-03	Reflected XSS in DVWA name field	Figs. 12.3–12.5	CWE-79	AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N = 5.4	Medium
F-04	Unauthenticated root backdoor on TCP/1524	Fig. 13.1	CWE-306	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H = 9.8	Critical
F-05	Anonymous FTP access enabled	Fig. 11.1	CWE-287	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N = 5.3	Medium
F-06	No lockout/rate-limit after repeated failed SSH logins	Figs. 14.2, 16.1	CWE-307	Not independently scored — contributing factor to F-01/credential risk	Medium (qualitative)
F-08	Apache/DVWA log forwarding to log box not confirmed	§15.2	CWE-778	Not applicable (configuration/coverage gap, not an exploit)	Medium (qualitative)
F-09	Path traversal reaches File Inclusion filesystem layer; verbose errors	Fig. 12.6	CWE-22 / CWE-209	Not scored — file disclosure not confirmed	Medium (qualitative, pending confirmation)
F-10	Command Execution module reached; payload/output unconfirmed	Fig. 16.3 (Apache log)	CWE-78	Not scored — impact not confirmed	Unknown (pending confirmation)

CWE and CVSS values above were assessed by the student against the evidence captured; they have not been independently verified against NVD/MITRE records for this exercise and should be treated as a graded learning exercise in scoring, not an authoritative vulnerability database entry.

23. Red Team vs Blue Team Reflection

What did the attacker know that the defender didn't?

As the attacker, I knew the exact payloads, timestamps, and source IP for every action I took — nothing was hidden from myself. Sitting down afterward as the "defender" with only the logs, that advantage disappeared: SSH activity was easy to find because the OS logs it by default, but the SQL injection and XSS attacks left almost no trace at the application layer, because DVWA does not log form submissions in a security-relevant way. The defender's view was strictly poorer than the attacker's, even for activity I already knew the answer to.

Which attack was hardest to detect, and why?

The SQL injection and XSS tests against DVWA were hardest to detect from logs. The only trace of them was in the local Apache access log (and even that only shows the raw URL, not that it was malicious) — nothing flagged them as different from ordinary traffic, and that log wasn't even confirmed to reach the central log box. The SSH activity, by contrast, was easy: auth.log labels failed logins explicitly.

What did the (incomplete) seeded incident teach that my own attacks didn't?

Even without a seeded incident to investigate, preparing for one was instructive: it forced me to think about what "activity I didn't cause" would actually look like against a baseline I understand, and it exposed how incomplete my own logging coverage is. Not being able to complete Task 3.3 was itself a lesson in how fragile an investigation is when a required input (the seed script) simply isn't available — a real SOC analyst sometimes has to say "I cannot complete this investigation with what I have," and documenting that honestly is itself the professional move, rather than inventing a plausible-looking incident.

24. Conclusion

This engagement successfully built and isolated a representative lab, demonstrated a complete attack path from reconnaissance to root-level compromise, confirmed two serious DVWA web-application vulnerabilities, and stood up a working (if incomplete) centralized logging pipeline that proved its value during manual SSH log analysis. The Core requirements that were not completed — a full Nmap sweep, the DVWA/FTP credential brute-force tasks, command-injection and file-inclusion confirmation, and the seeded-incident investigation — are documented transparently above rather than claimed. SecureCorp's most urgent exposure is the unauthenticated root backdoor on TCP/1524; everything else in this report is secondary until that is remediated.

25. References

- SecureCorp — Security Assessment Engagement (v2), Junior Cybersecurity Consultant Handbook, v2.1 (2026-09-10).
- OWASP, "SQL Injection," owasp.org.
- OWASP, "Cross-Site Scripting (XSS)," owasp.org.
- MITRE, CWE-798: Use of Hard-coded Credentials, cwe.mitre.org.
- MITRE, CWE-89: SQL Injection, cwe.mitre.org.
- MITRE, CWE-79: Cross-site Scripting, cwe.mitre.org.
- MITRE, CWE-306: Missing Authentication for Critical Function, cwe.mitre.org.
- MITRE, CWE-307: Improper Restriction of Excessive Authentication Attempts, cwe.mitre.org.
- MITRE, CWE-22: Improper Limitation of a Pathname to a Restricted Directory, cwe.mitre.org.
- FIRST, Common Vulnerability Scoring System v3.1 Specification, first.org.
- Rapid7, Metasploitable2 documentation, docs.rapid7.com.
- DVWA Project, Damn Vulnerable Web Application documentation, dvwa.co.uk.

26. Appendices

Appendix A — Evidence Inventory (screenshot → task mapping)

File (as supplied)	Mapped to
metasplotable ip set up.png	§4.1 — Target static IP
ubuntu ip.png	§4.1 — Log-box static IP
pinging metasploitable from kali.png / pinging kali from metasploitable.png	§4.2 — Kali↔Target connectivity
kali to ubuntu pinging.png / metasploitable to unbuntu ping.png / ubuntu to metasploitable pinging.png	§4.2 — Remaining connectivity pairs
default creds vulnerablity.png	§4.3 / Finding F-01
setting dvwa security to low.png	§4.3 — Baseline configuration
changing password for metasploitable.png	§4.4 — Default-credential remediation
exploiting a real vuln.png	§9 — Nmap scan of port 1524
exploited a real vuln on port bind shell.png	§13 / Finding F-04
ftp access.png	§11 / Finding F-05
sql injection revels admin.png / sqlinjection using1'OR'1'='1'#.png	§12.1 / Finding F-02
xss testing.png / xss testing-2.png / xss scripting - 3.png	§12.2 / Finding F-03
file incluison vuln.png	§12.3 / Finding F-09
sending log from metasploit to ubuntu.png / appered log in ubuntu.png	§15 — Logging pipeline setup
intentional ssh fail login from kali.png / intentinoal ssh log fail kali.png	§15.1 — Failed-login pipeline verification
ssh access from kali to metasploitable.png	§14.1 — Legitimate SSH login
ubuntu log checkup.png	§16.1 — Extended failed-login review
investigating successful logins.png	§16.2 — Successful logins / sudo
apache log access logs.png	§16.3 — Local Apache access log
command execution vuln.txt / file inclusion vuln.txt / ftp vuln report.txt / xss vulnerablity.txt	Student's own finding-template notes, incorporated into §12 and §22

Appendix B — Mandatory Requirements Not Completed

Listed here in one place for transparency, matching Appendix E of the handbook:

- Full-range Nmap service/version sweep with saved output (-oA) — only a single-port scan supplied.
- DVWA Brute Force module test (Task 2.4) — not evidenced.
- FTP credential brute-force with recorded attempts (Task 2.7) — only anonymous access tested.
- SSH brute-force against a dedicated weak-password test account with recorded attempt count (Task 2.8) — only ad hoc failed logins evidenced.

- Command Injection payload/output screenshot (DVWA module) — only endpoint access via Apache log.
- Confirmed File Inclusion file disclosure — only traversal attempt and error output evidenced.
- Apache/DVWA access-log forwarding to the centralized log box — not confirmed; only the local copy was reviewed.
- Seeded-incident investigation (Task 3.3) — instructor-provided seed script/evidence bundle was not supplied.
- Week 1/Week 2 snapshot screenshots — not supplied.
- Wazuh/SIEM Challenge path — not attempted (optional).

Appendix C — Research Log (summary)

A detailed, dated research log (tool, error text, source consulted, resolution) was referenced in the project workflow but was not supplied as part of the uploaded evidence for incorporation into this report. Recommend attaching it as a standalone appendix file before final submission.

Security Assessment and Centralized Logging Report

Project Title: SecureCorp – Security Assessment and Centralized Log Monitoring
Domain: Cybersecurity – Network Security and Vulnerability Assessment
Environment: VirtualBox Virtual Lab
Target System: Metasploitable 2
Testing System: Kali Linux
Log Collection System: Ubuntu Server

Target IP Address: 10.10.10.10
Attacker IP Address: 10.10.10.5
Log Server IP Address: 10.10.10.20

Prepared by: Ravi Sankar Akula
Date: 17 October 2026